

MEDIROZA GENERAL HOSPITAL

PENETRATION TESTING REPORT

Black-Box Web Application Penetration Test

Target	https://medirozahospital.com
Assessment Type	Black-Box Web Application Penetration Test
Batch	B083
Week	4
Duration	5 Days
Author	Komguep Nelly
Report Date	01 October 2026

TABLE OF CONTENTS

TABLE OF CONTENTS.....	2
01 EXECUTIVE SUMMARY	4
Findings Summary.....	4
02 SCOPE AND METHODOLOGY.....	5
2.1 Scope.....	5
In Scope.....	5
Out of Scope.....	5
2.2 Methodology.....	5
M1 — Initial Access.....	5
M2 — Data Extraction.....	6
M3 — Critical Data Exposure	6
03 FINDINGS AND PROOF OF EXPLOITATION	7
MED-01 — Information Disclosure Through Exposed Web Resources	7
MED-02 — Sensitive Patient-Report Exposure.....	7
MED-03 — Recoverable Protection of Retrieved PDF Documents.....	8
MED-04 — Exposure Through Historical Resources	8
MED-05 — Exposure of Employee Salary and Shareholder Information	9
03.6 — Metadata Information Disclosure	10
04 RISK RATING	11
Risk Summary.....	11
05 RECOMMENDATIONS AND REMEDIATION	12
5.1 Access Control.....	12
5.2 Secure File Storage.....	12
5.3 Directory Hardening.....	12
5.4 Backup Security.....	12
5.5 Document Protection.....	12
5.6 Metadata Management.....	12
5.7 Sensitive Data Protection.....	12
5.8 Monitoring	12
5.9 Post-Remediation Testing	13
06 CONCLUSION.....	14
APPENDIX A — EVIDENCE MAP	15

M1 — Initial Access 15

M2 — Data Extraction..... 15

M3 — Critical Data Exposure 15

APPENDIX B — EVIDENCE HANDLING..... 16

01 EXECUTIVE SUMMARY

This report presents the results of a five-day black-box penetration testing assessment performed against the authorized Mediroza General Hospital web application as part of the NetworkWalks Batch B083 Week 4 cybersecurity training.

The assessment was divided into three technical phases:

- M1 — Initial Access
- M2 — Data Extraction
- M3 — Critical Data Exposure

The assessment identified several security weaknesses involving exposed application resources, sensitive patient reports, recoverable document protection, historical resources, document metadata, and exposure of sensitive organizational information.

The investigation ultimately demonstrated that sensitive information could be exposed beyond the application's normal user interface.

For privacy and security reasons, this public report does not reproduce actual patient records, employee salary values, shareholder records, passwords, credentials, or other confidential information.

Findings Summary

ID	Finding	Module	Risk
MED-01	Information disclosure through exposed web resources	M1	MEDIUM
MED-02	Sensitive patient-report exposure	M1	HIGH
MED-03	Recoverable protection of retrieved PDF documents	M2	HIGH
MED-04	Exposure through historical resources	M3	HIGH
MED-05	Employee salary and shareholder information exposure	M3	CRITICAL

02 SCOPE AND METHODOLOGY

2.1 Scope

Target: <https://medirozahospital.com>

In Scope

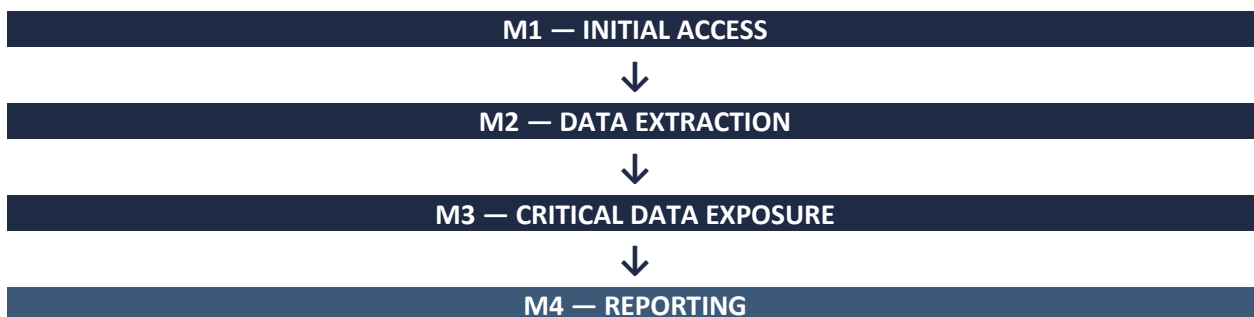
- Web application functionality
- Publicly accessible resources
- Authentication-related functionality
- Accessible directories and files
- Authorized patient-report functionality
- Exposed information discovered during the assessment
- Document and metadata analysis

Out of Scope

- Denial-of-Service attacks
- Social engineering
- Destructive testing
- Attacks against third-party systems
- Unauthorized access to external systems
- Publication of confidential medical information

2.2 Methodology

The assessment followed a black-box penetration testing methodology, structured across four sequential phases:



M1 — Initial Access

The first phase included:

- Target identification
- robots.txt analysis
- Web resource enumeration
- Patient directory discovery
- Authentication analysis
- Authorized access to the patient portal
- Retrieval of three patient PDF reports

M2 — Data Extraction

The second phase focused on the three retrieved PDF documents. Activities included:

- Hash extraction
- Password recovery
- Processing of the different PDF protection mechanisms
- Decryption
- Verification of the recovered reports

M3 — Critical Data Exposure

The third phase focused on identifying additional sensitive information. Activities included:

- Examination of the /old/ directory
- Analysis of exposed data
- Metadata analysis
- Identification of employee salary information
- Identification of shareholder information

03 FINDINGS AND PROOF OF EXPLOITATION

MED-01 — Information Disclosure Through Exposed Web Resources

RISK

MEDIUM

Description

Application enumeration revealed publicly accessible resources that disclosed information about the application's structure. The investigation included analysis of robots.txt and accessible application directories.

Evidence

01-target.png
02-robots-txt.png
03-patient-directory.png

Impact

Exposed paths can assist an attacker during reconnaissance by revealing application components and potentially sensitive resources.

Recommendation

- Minimize unnecessary information disclosure.
- Remove obsolete public resources.
- Review robots.txt entries.
- Apply appropriate server-side access controls.
- Regularly audit publicly accessible directories.

MED-02 — Sensitive Patient-Report Exposure

RISK

HIGH

Description

During the authorized assessment, three patient PDF reports were successfully retrieved through the application's report functionality. The actual medical records are intentionally not reproduced in this report.

Evidence

M1 evidence documents the process used to identify and retrieve the reports.

Impact

Unauthorized exposure of medical information can have significant confidentiality and privacy consequences.

Recommendation

- Enforce authorization on every report request.

- Store sensitive reports outside the public web root.
- Use controlled download mechanisms.
- Prevent direct access to sensitive files.
- Log and monitor sensitive document downloads.
- Review access-control rules regularly.

MED-03 — Recoverable Protection of Retrieved PDF Documents

RISK

HIGH

Description

During M2, the three retrieved PDF documents were processed through hash extraction and password recovery. The recovered passwords allowed the protected reports to be opened and verified. One of the PDF processing operations required a wordlist before successful processing could continue.

Evidence

Hash extraction for PDF 1
Hash extraction for PDF 2
Initial PDF 3 processing
Wordlist loading for PDF 3
Password recovery results
Decrypted reports

Impact

If an attacker obtains protected documents and the document passwords can subsequently be recovered, the confidentiality provided by document-level protection is reduced.

Recommendation

- Use strong and unique document encryption credentials.
- Avoid relying exclusively on PDF passwords.
- Enforce authorization before document download.
- Store sensitive documents securely.
- Apply application-level access controls.
- Review document protection mechanisms periodically.

MED-04 — Exposure Through Historical Resources

RISK

HIGH

Description

During M3, an accessible /old/ directory was identified. Further examination of the exposed resources led to the discovery of additional sensitive information. Historical or obsolete resources should not remain publicly accessible when they contain confidential information.

Evidence

01-old-directory.png
02-exposed-data.png

Impact

Historical resources may expose forgotten information, application artifacts, backups, or organizational data.

Recommendation

- Remove obsolete files from the web root.
- Disable unnecessary directory listing.
- Store backups outside publicly accessible directories.
- Implement secure backup management.
- Establish data-retention policies.
- Periodically scan the web root for forgotten resources.

MED-05 — Exposure of Employee Salary and Shareholder Information

RISK

CRITICAL

Description

The exposed data identified during M3 included salary information concerning hospital employees and information concerning the hospital's shareholders. The actual names, salary values, and shareholder records are intentionally omitted from this public report.

Evidence

02-exposed-data.png (primary evidence)
03-metadata-normal-author.png (additional metadata evidence)
04-metadata-jmalik-anomaly.png (additional metadata evidence)

Impact

The exposure of employee salary and shareholder information represents a significant confidentiality and privacy concern. Such information may reveal sensitive personal and organizational details to unauthorized users.

Recommendation

Immediate remediation should include:

1. Removing sensitive data from publicly accessible resources.
2. Restricting access through server-side authorization.
3. Reviewing historical and backup directories.
4. Applying least-privilege principles.
5. Auditing access logs.

6. Reviewing data-retention policies.
7. Conducting a follow-up security assessment.

03.6 — Metadata Information Disclosure

During M3, metadata associated with analyzed resources was examined. Two observations were documented:

- A normal author metadata value.
- An anomalous author value associated with JMalik.

Evidence

03-metadata-normal-author.png
04-metadata-jmalik-anomaly.png

Security Impact

Document metadata can reveal information about:

- Document authors
- Document creation
- Application environments
- Internal organizational processes

Recommendation

Unnecessary metadata should be removed from documents before external distribution or publication.

04 RISK RATING

The assessment uses four qualitative risk levels.

Level	Description
CRITICAL	Severe exposure of highly sensitive information with major confidentiality or privacy implications.
HIGH	Significant security impact affecting sensitive application or document resources.
MEDIUM	Meaningful information disclosure or attack-surface expansion with more limited direct impact.
LOW	Limited direct impact requiring remediation as part of defense-in-depth.

Risk Summary

Finding	Risk
MED-01	MEDIUM
MED-02	HIGH
MED-03	HIGH
MED-04	HIGH
MED-05	CRITICAL

The highest-priority remediation area identified during the assessment is the exposure of highly sensitive employee and organizational information.

05 RECOMMENDATIONS AND REMEDIATION

5.1 Access Control

Implement server-side authorization checks for every sensitive endpoint and file request. Access should follow the principle of least privilege.

5.2 Secure File Storage

Sensitive files should not be stored directly inside publicly accessible web directories. Patient reports, backups, archives, and confidential documents should be stored in protected locations.

5.3 Directory Hardening

Disable unnecessary directory listing and remove obsolete resources from the web root.

5.4 Backup Security

Backups should:

- Be stored outside the web root.
- Have restricted permissions.
- Be encrypted where appropriate.
- Follow defined retention policies.
- Be regularly audited.

5.5 Document Protection

Document encryption should complement, not replace, application-level authorization. Sensitive documents should only be downloadable after successful authorization.

5.6 Metadata Management

Remove unnecessary author and application metadata before documents are externally distributed.

5.7 Sensitive Data Protection

Employee salary and shareholder information should be accessible only to explicitly authorized personnel. Access should be logged and periodically reviewed.

5.8 Monitoring

Implement monitoring for:

- Sensitive file access

- Repeated download attempts
- Unusual access patterns
- Access to historical resources
- Unauthorized requests

5.9 Post-Remediation Testing

After applying the corrective measures, a focused retest should verify:

- Access control
- Direct file access
- Directory exposure
- Historical resources
- Backup exposure
- Sensitive-data access
- Document authorization

06 CONCLUSION

The Mediroza General Hospital penetration testing assessment demonstrated several security weaknesses affecting information confidentiality and application exposure. The three technical phases revealed:

- Application resource disclosure.
- Exposure of sensitive patient reports.
- Recoverable PDF protection.
- Historical resource exposure.
- Metadata information disclosure.
- Employee salary information exposure.
- Shareholder information exposure.

The findings demonstrate the importance of implementing a defense-in-depth security strategy combining:

- Strong access control
- Secure file storage
- Protected backups
- Document security
- Metadata management
- Least privilege
- Monitoring and logging
- Regular penetration testing

The most sensitive information identified during the assessment has deliberately been excluded from this public report.

APPENDIX A — EVIDENCE MAP

M1 — Initial Access

```
M1-INITIAL-ACCESS/  
└─ screenshots/  
    └─ 01-target.png  
    └─ 02-robots-txt.png  
    └─ 03-patient-directory.png  
    └─ 04-login-page.png  
    └─ 05-login-request.png  
    └─ 06-login-response.png  
    └─ 07-portal-authentication-protection.png
```

M2 — Data Extraction

```
M2-DATA-EXTRACTION/  
└─ screenshots/  
    └─ 01-hash-pdf-01.png  
    └─ 02-hash-pdf-02.png  
    └─ 03-hash-pdf-03-wordlist-required.png  
    └─ 04-hash-pdf-03-wordlist-loaded.png  
    └─ 05-password-crack-pdf-01.png  
    └─ 06-password-crack-pdf-02.png  
    └─ 07-password-crack-pdf-03.png  
    └─ 08-report-pdf-01-decrypted.png  
    └─ 09-report-pdf-02-decrypted.png  
    └─ 10-report-pdf-03-decrypted.png
```

M3 — Critical Data Exposure

```
M3-CRITICAL-DATA-EXPOSURE/  
└─ screenshots/  
    └─ 01-old-directory.png  
    └─ 02-exposed-data.png  
    └─ 03-metadata-normal-author.png  
    └─ 04-metadata-jmalik-anomaly.png
```

APPENDIX B — EVIDENCE HANDLING

The following information should NOT be committed to a public GitHub repository:

- Original patient reports
- Patient medical information
- Employee names and salary values
- Shareholder records
- Passwords
- Authentication credentials
- Cookies or session tokens
- Unredacted confidential screenshots

Only appropriately redacted technical evidence should be published.

DISCLAIMER

This document records an authorized educational penetration testing exercise. Testing activities were limited to the designated Mediroza General Hospital target and the defined assessment scope. No unauthorized systems were intentionally targeted.

Project	Mediroza General Hospital Penetration Testing
Batch	B083
Week	4
Author	Nelly
Assessment Type	Black-Box Web Application Penetration Test